

Основи на мрежовата сигурност – DuoDesign

- Сигурност - да не се разпадне системата и да не се подменят данните.
- Сложността на технологиите нараства, но броят на хората, които разбират как функционират намалява.
- Пробив = пари + репутация

Пробиви: спам съобщения, подмяна на самоличност, подслушване, рекламни страници върху чужд сайт, автоматични скриптове за логин – сървърът е зает и отказва достъп на упълномощени акаунти, e-mail сървър – не може да изпраща и получава, в банките – прехвърляне на големи суми, откраднати HDD

DNS – Domain Name System – URL пренасочва името на сайта към друго IP (с цифри)

DOS – Denial Of Service – отказ от услуга – например неупълномощено качване на голям обем данни чрез FTP: блокира дисково пространство, генерира мрежов трафик, упълномощени потребители нямат достъп.

DDOS – **Distributed** DOS – 1 сървър е мишена от много различни компрометирани системи.

! Законово, всяка система е длъжна да опазва ресурсите си от злоупотреба, съответно носи наказателна отговорност.

Области за защита:

- 1) Клиент (вируси, кражби)
- 2) Сървър (забавяне, спиране, използване на ресурси)
- 3) Мрежа (подслушване, фалшива самоличност)

Клиентски браузър -> заявка до www.xyz.com -> DNS server -> IP -> Web server -> зареждане на стр.

* 80% от пробивите са поради лош подбор на пароли според CERT/CC на CMU – Computer Emergency Response Team / Coordination Center of Carnegie – Mellon University.

.....

Why most cybersecurity advices are useless:

https://www.youtube.com/watch?time_continue=58&v=5y4_k25kMfY

“Strong password” – you could use 64-character encrypted haiku with a fingerprint scan and some Kali Linux user can download your entire account from leaky AWS bucket.

2015 – Ashley Madison data breach - https://en.wikipedia.org/wiki/Ashley_Madison_data_breach

If you use Base64 instead of hashing and don't turn off their public S3 (Simple Storage Service) bucket <https://aws.amazon.com/s3/> . Crackers just buy the entire DB from DarkWeb.

Apps do nothing against to detect Login attempts from 12 countries in 5 minutes.

Phishing –

WebAuthn, short for Web Authentication, is a web standard that enables secure, passwordless authentication using public-key cryptography

The Equifax data breach - 2017, American credit bureau Equifax was breached. Private records of 147.9 million Americans along with 15.2 million British citizens and about 19,000 Canadian citizens were compromised in the breach, making it one of the largest cybercrimes related to identity theft. The reason: **Unpatched Apache server**. <https://ccb.belgium.be/advisories/warning-critical-vulnerability-patched-apache-http-server-2460-patch-immediately>

The SolarWinds data breach 2023 – hackers inserted malicious code (malware) into Orion updates, allowing them to infiltrate the networks of thousands of organizations, including government agencies and private companies. The SolarWinds hack was a major event not because a single company was breached, but because it triggered a much larger supply chain incident that affected thousands of organizations, including the U.S. government. SolarWinds is a major software company based in Tulsa, Okla., which [provides system management tools](#) for network and infrastructure monitoring, and other technical services to hundreds of thousands of organizations around the world. Among the company's products is an IT performance monitoring system called Orion.

The Colonial Pipeline cyber attack 2021 - a ransomware attack to extort money from the Colonial Pipeline system, a major fuel pipeline in the United States - transports gasoline, diesel, and jet fuel along the East Coast. Leaked VPN + *inactive account* that didn't use MFA (MultiFactor Authentication).

Ransomware is a type of malware which **prevents you from accessing your device and the data stored on it, usually by encrypting your files**. A criminal group will then demand a ransom in exchange for decryption. The computer itself may become locked, or the data on it might be encrypted, stolen or deleted. <https://www.ncsc.gov.uk/ransomware/home>

Leaked VPN – there are VPN leak test, DNS leak test, IPv6 leak test...

If there is an existing connections before the VPN is connected stay open after the VPN is connected.

When you do a leak test, it will tell you that everything is OK because the test creates new connections which will stay within the VPN tunnel. <https://www.pcwrt.com/2023/05/a-vpn-leak-in-windows-10/>

MOVEit data breach 2023 – an app to transfer files.

A zero-day attack is a cyberattack that exploits a previously unknown software vulnerability before a patch or fix is available.

.....

! Вътрешни пробиви се крият, за да запазят репутацията.

Цели:

- 1) Поверителност – Confidential – само за упълномощени имат достъп
- 2) Цялостност - само упълномощени редактират
- 3) Достъпност - при DOS – заради много заявки от неоторизирани потребители, упълномощените нямат достъп.
- 4) Автентификация – логин за различни роли.

Уравнение на сигурността = цената на сигурността в пари:

- + реална стойност (пазарна, достигане, възстановяване, загуби)
- + възприета стойност (нечестно продадена при конкуренцията)

- + защита (< от реалната + време + усилие)
- + пробив (> от възприетата печалба + заплати за бели хакери, инструменти, време)

Екип за управление на риска (стари контроли + нови)

Заплахи и уязвимости:

- * вътрешни/външни
- * физически (компютри и кабели)/електронни
- * известни/неизвестни

Електронните заплахи са по-скъпи от физическите (от 1 служител).

White hat hackers – намират и докладват уязвимости, предлагат решения.

Code ret – 2001 – червей, който атакува MS IIS – Internet International Server. Показвал съобщение „Hacked by Chinese!“ на всички сайтове на даден сървър, препълвал паметта/buffer overflow като записвал ‘N’.

Организации за сигурност: SANS, CERT, MS, FBI.

Случайни заплахи – човешки грешки и дори слаби пароли, транзакции.

Злонамерен софтуер:

- вирус – самокопира се и прикачва към други файлове във фонов режим
- троянски кон – създаден като полезна програма (игра), но кредитни данни с фалшиви изгледи
- червей – от файл на файл (но напускат документа) – прикачват се, самокопират се, не заразяват други програми.

Социално инженерство = „Хакване на хора“ – външен човек се преструва и несъзнателно служител му дава инфо.

Не работи: http://packetstorm.decepticons.org/docs/social-engineering/soc_eng2.html

Не работи: <http://www.vigilante.com/internetsecurity.socialinteneerign.html>

Един от най-добрите и издирвани хакери е Кевин Митник, който после работи за ФБР.

Основни техники:

- Директен – лъже, изнудва, ласкае
- Старши/важен служител – фалшива самоличност, притиска „подчинените“ с крайни срокове. Набавя инфо за RAS – Remote Access Server – адрес, достъп, име, парола, конфигурация...
- Нов/безпомощен служител – секретарка му дава достъп до съществуващ акаунт и парола на друг служител или дори собствения.
- Техническа поддръжка/сис админ – акаунт + парола за тест
- RSE – Reverse Social Ingeneering – обърнато социално инженерство: нарушителят внася безпорядък, а после „помага“ на служителя-жертва, който му задава въпроси: саботаж/безпорядък -> реклама -> асистирание/помощ

- E-mail анкети по чувствителни теми за кражба на данни
- Frame-spoofing измама в структурата – вкарват се допълнителни полета код в страницата на даден сайт (например за банкови карти) или JS реклами с порно съдържание, или заплащане за подновяване на ISP – Internet Service Provider – доставчик на интернет
- Crack на парола – хакерът влиза с чужд акаунт с пълномощия

Хеширане = добавяне/заместване на произволен брой символи на различни места до достигане на определена дължина.

X – оригинална парола (Maria)

F – криптираш алгоритъм (function)

h – hash – хеширан резултат

$F(x) = h$

$F(\text{Maria}) = 45M64a8ria12$

Хеширането е еднопосочно действие. То зависи от дължината на паролата.

Ако знаем F и h не можем да изчислим x.

Хеш стойностите само се сравняват.

Продават се пароли + хеш за сравнение.

- Dictionary attack – речникова – при обикновени думи
- Кратки атаки – малък брой пароли се тестват върху различни системи
- Brute Force attack – вътрешен служител предоставя списък с истински пароли от източник. Хакерът ги криптира със същия алгоритъм на системата до hash. Накрая сравнява резултатите с хешовете от БД.

! В миналото, при статичните сайтове не е имало толкова рискове. Firewalls позволяват достъп само през определени портове.

TCP/IP – Transmission Control Protocol / Internet Protocol – интерфейс за логическо свързване = порт.

http – обикновено използва **порт 80** за връзка към web server. Някои хакери атакуват системата дори през него.

- Превишаване на права
- Third-party – с вратички
- Сървърите – най-сигурно е да предлагат само 1 услуга, останалите да се спрат:
 - Root потребител – свръхпотребител
 - Къси имена на файловете са по-добре, т.к. дългите могат да се заобикалят като услуга
 - Лошо написани CGI скриптове по подразбиране от сървър -> динамични сайтове
 - http – несвързан, не запазва сесия (id). Cookies вземат id на сесия + id на потребител -> транзакция до БД на сървър през текстов редактор.

Превземане на сесия: чрез редактиране на разширен URL през текстов редактор.

- Атаки по email: бомбардиране, спам, подслушване (пропуска се важен email). Вид DOS

Email Boomber – продават се в сайтове на DW – около 14\$ за 5000 писма, но има и повече.

<https://github.com/ismailmazumder/Email-Bomber/blob/master/main.py>

Doomsday virus – от фентъзи, засяга всички, освен Wonder Woman, заради имунитета ѝ.

- Прихващане на пакет = sniffing + spoofing (подслушване + измама)

Достъп до файлове с пароли, атака на мрежа (модем, сучич) през backdoor, която обикновено се оставя отворена нарочно за достъп по всяко време и така се заобикаля вписване в logs.

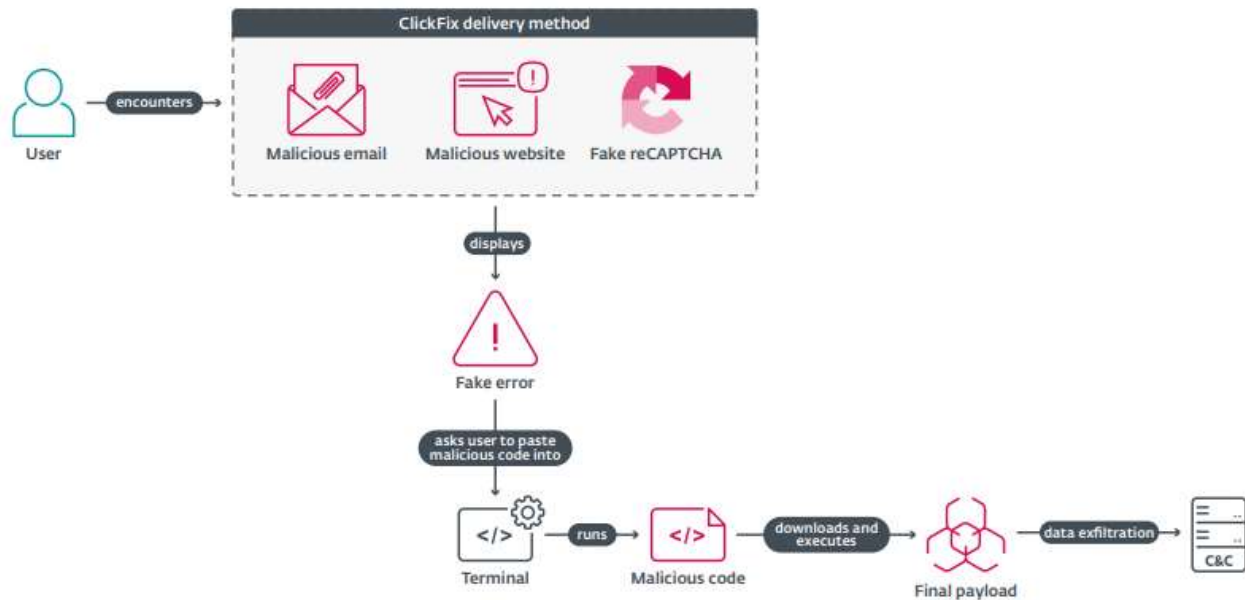
.....

Вируси – появяват се 80-те, обикновено са писани на Assembler. Десетилетия наред, 80% от вирусите са разпространявани чрез Word и Excel (защото поддържат макроси) по имейли, а основна уязвимост е била слабата парола. Вирусите се самокопират върху HDD и спаят от логнат имейл.

Днес, най-интензивно се развиват:

- * Фишинг – имитира сайт за кражба с банково плащане
- * ClickFix – фалшиво съобщение за грешка и верификация HTML/FakeCAPTCHA – следват се инструкции за въвеждане на зловреден код в терминала, които изтеглят вирус – [kaldata – ESET](#)
- * ransomware – криптират файловете, изискват плащане за декриптирането, но веднъж платил, после набелязват жертвата като потдатлива и започват да я атакуват по всякакъв начин с други вируси Double trouble.

Статистика на ESET за 2025: <https://web-assets.esetstatic.com/wls/en/papers/threat-reports/eset-threat-report-h12025.pdf>



Примери:

- Lumma Stealer (aka LummaC2 Stealer) is an information stealer written in C language that has been available through a Malware-as-a-Service (MaaS) model on Russian-speaking forums since at least August 2022. It is believed to have been developed by the threat actor "Shamel", who goes by the alias "Lumma". Lumma Stealer primarily targets cryptocurrency wallets and two-factor authentication (2FA) browser extensions, before ultimately stealing sensitive information from the victim's machine. Once the targeted data is obtained, it is exfiltrated to a C2 server via HTTP POST requests using the user agent "TeslaBrowser/5.5". The stealer also features a non-resident loader that is capable of delivering additional payloads via EXE, DLL, and PowerShell.
- Danabot is an infostealer written in Delphi. Cybercriminals have employed Danabot **in quite a number of ways**: apart from the typical data exfiltration capabilities, such as keylogging, screen recording, and file grabbing, the malware is also used to distribute further malware – even ransomware – to compromised systems. We have observed it pushing, among other payloads, LockBit, Buran, and Crisis. Additionally, machines compromised by the infostealer have been employed to launch DDoS attacks.
- AgentTesla, SnakeStealer – популярни кийлогъри.
- Kaleidoscope – за Android – има чиста версия в appstores и заразена – пуска реклами

Лятото на 2025 – група DragonForce е Ransomware-as-a-Service – RAAS – предлагат зловреден софтуер – влизат в конфликт с други групи и свалят сайтове от тъмната мрежа BlackLock, Матона, и най-големите RaaS за времето си – RansomHub, правейки данните на жертвите достъпни – изтичане на лични данни от сайт - data leak site (DLS).

Друга класация на вируси:

- Botnet – голямо количество прихванати компютри, които могат да бъдат управлявани дистанционно remote.
- Malware – краде информация и унищожава PC

- Worm – самокопира се.

Според <https://pcguide.bg/kakvo-e-malware-i-kak-da-se-zashtitim/>

Malware – сборно понятие за зловреден софтуер, което включва:

- * вируси – обикновено се прикачват към изпълними файлове, самокопират се
- * червеи – самокопират се, но пускат файла
- * троянски коне – маскират се като полезна програма
- * spyware – шпионско софтуер – краде лични данни, следи трафик
- * adware – пуска реклами
- * browser hijackers – екстеншъни за браузър, които променят настройките на браузъра
- * keyloggers – записват въведеното от клавиатурата
- * rootkits – предоставят админски достъп до системата, остават скрити за антивирусните, разпространяват се от заразени сайтове или p2p – peer-to-peer

13-те най-опасни вируса в историята: <https://etactics.com/blog/scariest-computer-virus>

- 1) MyDoom – 2004 – email вирус, който инфектира windows, с най-много щети 40 млрд \$.
- 2) Sobig – 2003 – вмъква се в .pif или .scr – много сходен с MyDoom, упдейтва се, дори кара принтерите да разпечатват безсмислици – 36 млрд \$ щети. Неизвестен създател.
- 3) Conficker aka Downup – 2008 – един от най-устойчивите червеи. Най-големият червей след Welchia – над 10 млн заразени компютъра, които образуват тъмен Botnet. Атакува администраторската парола. Опитва се да свали фалшива антивирусна. Никога няма да се разбере какво точно прави, т.к. е от неизвестен създател.
- 4) Welchia aka Nachi Worm – 2003 – един от най-уникалните, т.к. е създаден, за да унищожи друг червей Blaster. Създаден да се разпространява и самоунищожи, след като Blaster изчезне, но причинява значително забавяне на системите и дори изключване. Нанася повече щети от червея, срещу когото е създаден и оцелява дори след унищожаването му.
- 5) Klez – 2001 – за разлика от другите вируси, той не се нуждае от download. Възползва се от слабости в Outlook и Internet Explorer и затова е било достатъчно само да се погледне preview на email.
- 6) ILOVEYOU aka love bug – 2000 – разпространява се като любовно писмо, но целта е да открадне пароли за необходими услуги и унищожава снимки, музика и документи. Създаден от студент във Филипините. Документът се е казвал "LOVE-LETTER-FOR-YOU.TXT.vbs", но т.к. суфиксът е скрит, получателите са виждали само .txt. Инфектира системната папка и регистъра, така че вирусът се активира още преди вписването на потребителя. https://github.com/bkimminich/it-security-lecture/blob/master/malware-profiles/2000_ILOVEYOU.md
- 7) WannaCry – 2017 – създаден от хакери в Северна Корея, разпространява се при обмен на файлове, стопиран е от 22-годишен британски изследовател.
- 8) Zeus aka The Banking Trojan – 2007 – разпространява се по имейл и засича логване на потребители в сайтове за електронно банкиране, краде паролите дори от Internet's Explorer Password Store, използва keylogger.
- 9) Melissa – 1999 – по имейл обещава документ с пароли за платени сайтове за възрастни 18+. Веднъж изтеглен, документът изпраща криптиран имейл на още 50 получателя от списъка, възползвайки се от макрос-функционалностите на Word и Outlook. Създателят Смит влиза в

затвора и плаща глоба.

<https://www.cs.miami.edu/home/burt/learning/Csc521.061/notes/melissa.txt>

- 10) Code Red – 2001 – един от малкото вируси, способни да се стартират само в паметта, без да инфектира файлове. Инфектира IIS и причинява DOS.



- 11) Stuxnet – 2010 – първото кибероръжие, което причинява хардуерни проблеми – cyberweapon. Възползва се от zero-day уязвимости и удря ядрените централи на Иран, газопроводи (gas pipes) и електроцентрали (power plants). Т.к. никой не поема отговорност, се смята, че това са САЩ и Израел.
- 12) CryptoLocker – 2013 – по имейл се разпространява чрез изтегляне, криптира файлове и предлага декриптиращ ключ срещу заплащане. Жертвите са били предварително набелязани след Gameover Zeus botnet. За 3 месеца около 1000 души са се съгласили да заплатят около 1000\$. Вирусът съществува около 10 м, но негови варианти са активни и до днес.
- 13) Jerusalem aka Friday 13th – 1988 – създателите са неизвестни, но се смята, че е по случай 40-годишния юбилей от създаването на Израел. Това е DOS – файлов инфектор. Тихо инфектира компютрите чрез CD, дискети и поща, а на петък 13-и се стартира, което забавя компютрите. Изтрива всички програми, които се използват на този ден. Някои експерти смятат, че може да бъде спряно като просто се премести календара на 14-и, но други казват, че това е неефективно, т.к. така или иначе забавя системата.

.....

Virus Information Summary List 1998 - <https://wiw.org/~meta/vsum/>

Други вируси – W97M/Class.D – Word 97 Macro virus, който прихваща username и го обижда.

CIH – познат още като Chernobyl / Spacefiller – 1998 – силно опасен, препрограмира Flash BIOS - .asm – на асемблер <https://github.com/onx/CIH/blob/master/cih-1.4.asm>

Езици:

- Машинен = само числа

- Assembler = думи – Cobol

ISCA Labs 6th Annual Computer. Virus Prevalence Survey 2000

Някои служители, които работят с клиенти са по-уязвими от други.

Вирусите могат:

- Повреждат ОС и имитират повреден хардуер
- Увреждат DOS програмни файлове .com, .exe, .sys, .dll, .bin, .drv, .ovl
- Разпространяват чрез офис документи, поддържащи макроси като Word и Excel

Типове вируси:

- 1) Стартово – секторни MBR – Master Boot Record – първият сектор, който се чете при зареждане в системната памент с информация на колко части е разделен HDD, информация за BIOS и др.

Примери:

* Disk Killer (Computer **Ogre / чудовище**) – 1980 – 90 - encrypting data on hard drives using a simple XOR method after a computer is active for 48 hours. The virus hides within the FAT (File Allocation Table) by marking specific sectors as "bad". On hard drives, it hides in sectors immediately **preceding (предходен)** the boot record.

* Stoned -

Следва продължение.